

TSHELO

Additional Relevant Controls

Bank of Botswana Regulatory Sandbox Application

Data Sentinels | 31 March 2026 | nbokete@data-sentinels.com | tshelo.com

This document supplements the control frameworks submitted under sections e(i) through e(vii) of Tshelo's Bank of Botswana Regulatory Sandbox application. It provides a consolidated reference to all submitted frameworks and sets out additional controls embedded in Tshelo's platform architecture and operations that are not covered elsewhere.

1. Summary of Controls Submitted

The following frameworks and procedures have been submitted as attachments to this application. Each constitutes a comprehensive set of controls in its own right:

Section	Document Submitted	Key Controls Covered
e(i)	Risk Management Framework	20-risk register across 5 categories. Escalation protocol. Inherent safeguards table.
e(ii)	ICT and Cybersecurity Management Framework	CIA triad controls. AES-256 encryption. RLS. Incident response. Data protection.
e(iii)	Business Continuity Plan	6 continuity scenarios. RTO and RPO targets. FIA compliance during disruption.
e(iv)	AML/CFT/CPF Risk Management Framework	12 controls mapped to FIA sections. STR reporting. 5-year record retention. Sanctions screening.
e(v)	Consumer Protection Framework	18 controls mapped to Consumer Protection Act 2018. Redress pathway. Vulnerable user protections.
e(vi)	Customer Complaints Handling Procedure	4-priority classification. 5-step process. 3 response templates. External escalation pathway.
e(vii)	Test Partner Safeguards	4 partner risk assessments. Agreement status and formalisation plan. Partner monitoring commitments.

2. Additional Platform Architecture Controls

The following controls are embedded directly in Tshelo's platform architecture and operations. They provide an additional layer of protection that complements the submitted frameworks.

Ref	Control	Description	Status
IDENTITY AND ACCESS			
A1	OTP identity verification for all accounts	Every user must verify their mobile number via a one-time password	IMPLEMENTED

		before any fund activity is permitted. No anonymous accounts.	IMPLEMENTED
A2	Session token expiry on inactivity	User sessions expire automatically after a defined inactivity period, requiring re-authentication via OTP to continue.	
A3	Row Level Security on all database tables	Every database query is scoped to the authenticated user via Supabase Row Level Security. Cross-user data access is prevented at the database level.	
FUND INTEGRITY			
F1	Immutable audit trail for all fund activity	Every contribution, expense, edit, and deletion attempt is permanently logged with a timestamp and user ID. Nothing can be hidden or silently altered.	IMPLEMENTED
F2	Explicit user confirmation before recording contributions	No contribution is recorded automatically. The fund organiser must explicitly confirm each detected contribution before it is added to the fund.	IMPLEMENTED
F3	Fund size cap of BWP 10,000	All funds are capped at BWP 10,000 during the sandbox period. Attempts to exceed this limit are rejected at system level.	IMPLEMENTED
F4	Maximum 2 active funds per user simultaneously	Users cannot create more than 2 active funds at any one time during the sandbox period, limiting exposure and preventing abuse.	IMPLEMENTED
F5	Fund growth rate monitoring and alerting	Unusual fund growth speed triggers an internal alert to the CEO for review. This is the primary fraud and AML detection mechanism.	IMPLEMENTED
F6	Closed-loop invite-only fund design	Funds are private and accessible only to individuals personally invited by the fund organiser. No public fund discovery or anonymous contributions.	IMPLEMENTED
DATA PROTECTION			
D1	Data minimisation	Tshelo collects only name and phone number. No ID numbers, financial credentials, biometric data, or payment card details are stored.	IMPLEMENTED
D2	SMS content never transmitted to Tshelo servers	SMS messages are parsed locally on the user's device. Only the extracted amount and sender name are sent to the server. Raw SMS text is never stored.	IMPLEMENTED

D3	PDF export available at any time	Users can export a complete PDF audit report of any fund at any time, before or after closure. This provides an independent offline record not dependent on platform availability.	IMPLEMENTED
D4	User data deletion on request within 30 days	Any user may request deletion of their personal data at any time. Requests are actioned within 30 days with written confirmation.	IMPLEMENTED
REGULATORY ENGAGEMENT			
R1	Proactive Bank of Botswana engagement	Data Sentinels met with BoB on 12 March 2026 and submitted a formal introductory letter. Monthly sandbox reports will maintain this ongoing engagement.	IMPLEMENTED
R2	NBFIRA consultation planned	Data Sentinels will consult NBFIRA during Month 1 of the sandbox to confirm no registration is required under their purview.	IN PROGRESS
R3	Designated compliance contacts	CEO is designated AML Compliance Officer and Consumer Protection contact. Single point of accountability for all regulatory matters during the sandbox.	IMPLEMENTED

3. Commitment to Continuous Improvement

Data Sentinels is committed to maintaining and enhancing all controls throughout the sandbox period. Specifically:

- All controls will be reviewed monthly and any gaps identified during testing will be remediated within 5 business days
- Any new risk or control gap identified during sandbox testing will be reported to the Bank of Botswana in the next monthly progress report
- Automated sanctions screening will be implemented before commercial launch, upgrading the current manual screening process
- Service outage notification system (status page and SMS alerts) will be implemented before sandbox launch in May 2026
- Formal API agreements with mobile money providers will be executed during the sandbox period and provided to BoB within 5 business days of execution
- A full controls review will be conducted before the final sandbox report is submitted, incorporating all lessons learned during the testing period